arXiv:2608.07705v1 [cs.AI] 7 Aug 2026

PROTECTING PATIENT PRIVACY IN CLINICAL FOUNDATION MODELS: TECHNICAL AND LEGAL PERSPECTIVES

A PREPRINT

Sana Tonekaboni*
Massachusetts Institute of Technology (MIT), Cambridge, USA
The Broad Institute of MIT and Harvard, Cambridge, USA
Borealis AI, Toronto, Canada
stonekab@mit.edu

Lena Stempfle*
Massachusetts Institute of Technology (MIT), Cambridge, USA
The Broad Institute of MIT and Harvard, Cambridge, USA
stempfle@mit.edu

Sasha Ronaghi
Stanford University, California, USA
sronaghi@stanford.edu

Corinna Coupette
Aalto University, Finland
Max Planck Institute for Tax Law and Public Finance, Germany
The Stanford Center for Legal Informatics, Stanford Law School, USA
corinna.coupette@aalto.fi

I. Glenn Cohen
Harvard Law School, Cambridge, USA
Petrie-Flom Center for Health Law Policy, Biotechnology & Bioethics
igcohen@law.harvard.edu

Emily Alsentzer
Stanford University, California, USA
ealsentzer@stanford.edu

Marzyeh Ghassemi
Massachusetts Institute of Technology (MIT), Cambridge, USA
mghassem@mit.edu

August 11, 2026

ABSTRACT

Clinical foundation models trained on large-scale patient data are increasingly used for decision support, screening, and public health. As deployment expands, privacy risk increasingly arises from model-mediated leakage, yet its prevalence and severity remain poorly quantified. Models can disclose sensitive training artifacts, enabling patient re-identification in ways not captured by data-handling controls alone. Existing frameworks, including HIPAA and GDPR, offer limited guidance for such indirect threats. We propose a practical framework for assessing privacy risk in clinical foundation models and illustrate realistic leakage scenarios across deployment settings, map them to legal regimes, and outline complementary technical and legal mitigations. Our analysis provides a context-aware risk assessment grounded in realistic usage to preserve the value of medical foundation models while rigorously safeguarding patient privacy.

Keywords AI safety · Privacy · Clinical foundation models

*equal contribution

1 Introduction

Medical foundation models (FMs) are rapidly integrating into clinical decision-making, triage, screening, and public-health planning [Gupta et al., 2024, McKinney et al., 2020, Tomašev et al., 2019, Bhargava et al., 2024]. Pretrained on large patient cohorts, they can be adapted to data-scarce settings [Moor et al., 2023, Tham et al., 2025] and used to support diagnosis, personalize risk prediction, and streamline clinical workflows with the potential to improve patient outcomes [He et al., 2025, Sun et al., 2025].

As FMs grow in scale and are adapted more broadly, privacy risk can arise from unintended data leakage, enabling re-identification even when trained on de-identified records [Benitez and Malin, 2010]. Importantly, the leakage pathways are highly context-dependent: they vary with how a model is shared, where it is deployed, and how it is used. Most clinical FMs are trained on de-identified personal health data [Guo et al., 2024, Sellergren et al., 2025, Guo et al., 2023] and deployed through two main pathways: (i) local deployment, and (ii) public release (Figure 1). In local deployments within healthcare systems, foundation models may be fine-tuned on institutional patient data and accessed by clinicians through secured on-premises or enterprise installations [Renc et al., 2024]. By contrast, public releases, via web-based interfaces (including general-domain tools used for health purposes) [Google Research, 2022, OpenAI, 2026], application programming interfaces (APIs), or downloadable model weights and specifications [Han et al., 2023, Xie et al., 2024], enable external developers, researchers, healthcare providers, and commercial actors to integrate models into downstream applications, build new tools, or further adapt them through fine-tuning and subsequent deployment.

FMs trained on personal health data expand the privacy threat surface because risk arises not only from access to the underlying records, but also from what can be inferred or reconstructed from model outputs. In this study, we focus on the privacy risk of information leakage that stems from model fragility and weakness [Carlini et al., 2019, Khandelwal et al., 2019, Benitez and Malin, 2010, Tirumala et al., 2022], rather than from explicitly sophisticated attacks such as social engineering, insider misuse, or targeted model exploitation. These risks are orthogonal to familiar clinical-environment threats such as phishing, credential compromise, and large-scale data breaches (as described in the U.S. Department of Health and Human Services breach portal [U.S. Department of Health and Human Services, Office for Civil Rights, 2025]), which in practice often provide a simpler and more reliable path to obtain sensitive information than model-centric attacks. However, leakage that occurs through model behaviour are not well addressed by existing regulatory frameworks such as HIPAA (Health Insurance Portability and Accountability Act) [U.S. Department of Health and Human Services, Office of the Assistant Secretary for Planning and Evaluation, 1996], the GDPR (General Data Protection Regulation) [European Parliament and Council of the European Union, 2016], or commissioned policy reports [Novelli et al., 2024, Barberá, 2025], because existing frameworks were primarily designed to govern static risks to the direct handling of data (e.g., data collection, access, and disclosure). As such, they tend to adopt a rigid, audit-oriented perspective, rather than accounting for dynamic, model-mediated leakage that can arise through learned parameters and generated outputs.

In this work, we examine the spectrum of leakage mechanisms in medical foundation models, propose a practical framework to assess their privacy risk, situate these risks within current legal regimes, and outline complementary technical and legal mitigation strategies.

First, we introduce a two-dimensional framework for assessing privacy risk in medical foundation models, characterized by i) the amount of prior information required to trigger data leakage, and ii) the type and extent of information that may be revealed. We find that risk occurs at various levels, from leaking pieces of linkable personal information to identifiable personal information, resembling categories recognized in privacy law and data protection regulation. We note that leakage of isolated linkable personal information poses minimal risk to patient privacy, but can be serious because it increases the likelihood of re-identification. Leakage of identifiable personal information represents the highest level of risk, as it directly exposes sensitive patient data.

Second, we situate these risks within existing legal frameworks for patient data protection, focusing on the regulatory landscape in the US and the EU, existing laws (HIPAA, GDPR, EU Artificial Intelligence Act (AIA)). We find that existing legal definitions of privacy protection are underspecified, and call for context-aware assessments grounded in realistic use and leakage scenarios rather than abstract or purely formal criteria [Holzenberger and Maxwell, 2025].

Finally, we outline practical mitigation strategies from both legal and technical perspectives, covering data sharing and model access, and highlight emerging legal proposals and potential regulatory adaptations. By proposing a two-dimensional, continuous, and context-aware framework for assessing and addressing privacy risk, we aim to advance the scientific and clinical value of medical FMs while rigorously safeguarding patient privacy. This review considers literature published up to March 2026, reflecting the state of the field at the time of writing.

2 Foundation Models in Healthcare

Healthcare foundation models can be categorized by the primary modality (or modalities) they are pretrained on (e.g., clinical text, medical imaging), and this matters for privacy because leakage from each modality can expose different types of sensitive information. These modalities include, but are not limited to, structured electronic health records (EHR) [Guo et al., 2024, Renc et al., 2024], clinical notes [Xie et al., 2025, Yang et al., 2022], medical images such as radiology scans [Wu et al., 2025], and biological measures [Thapa et al., 2026, Li et al., 2025]. A common FM development pathway aggregates data from multiple providers (e.g., Hospital A/B/C), followed by harmonization, de-identification, and centralized or federated training to produce a foundation model intended for reuse across settings [Jeong et al., 2026]. In many such pipelines, the pretraining data is de-identified and HIPAA/GDPR compliant [Bednarz et al., 2025].

Once trained, models are distributed in several ways (Figure 1). First, (i) **Local deployment**, where locally deployed copies are hosted within a health system's secure environment. In such settings, the hospital may use local identifiable data to fine-tune the model, either as a one-time process or continually, but the use is limited to the protected fire-walled/certificate-based system [Renc et al., 2024, Jun et al., 2026]. Alternatively, third-party vendors may acquire clinical data to fine-tune foundation models into downstream products, which are then deployed and integrated into hospital workflows. In such settings, fine-tuning can use identifiable or de-identifiable. In many such settings, deployment is limited to controlled releases within regulated environments, where the model is protected under safeguards similar to those applied to patient data.

The second distribution type is (ii) **Public release**, in which the model is distributed as a web application with a user interface, exposed as a "black-box" service via an application programming interface (API), or released as downloadable weights that can be used as-is or further fine-tuned. These release channels differ materially in who can interrogate the model and under what controls, which in turn shapes the privacy threat surface. For instance, interface-based outputs may produce more heterogeneous outputs due to context loading, session history, and personalization effects, while APIs tend to be more controlled and reproducible [Wang et al., 2025]. Furthermore, clinical language models are often continually pre-trained or fine-tuned from base models whose data mixture is unknown to developers [Sellergren et al., 2025]. If these base models include sensitive health-related data, they may unintentionally encode and leak identifiable patient information, even when downstream clinical training data is privacy-compliant.

Overall, differences in data modality, training setup, and model release strategy lead to different privacy risk profiles in healthcare foundation models. Even when models are developed in compliance with HIPAA or GDPR, privacy risks can persist due to model capacity, fine-tuning and model deployment. To systematically analyse these privacy risks across deployment contexts, we introduce a two-axis framework that characterizes how leakage arises and what information may be exposed.

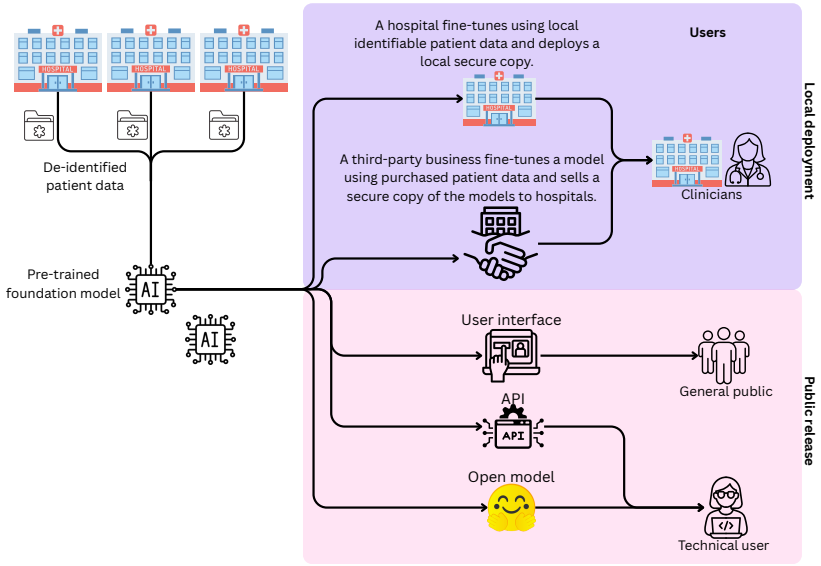
3 Contextualized Privacy Risk Assessment of Foundation Models

To better capture and understand the privacy risk of clinical foundation models, we characterize information leakage along two orthogonal axes (Figure 1b): (i) the **prior information** that initiates a leak, (ii) the **type and sensitivity** of the information that is leaked by a model. Together, these dimensions define a space of privacy risks that reflects both what the model exposes and the context in which that exposure is made possible. In a practical analysis, privacy risk is determined jointly by what the model can leak and how likely it is that the required prior information is available or can be obtained in the relevant setting.

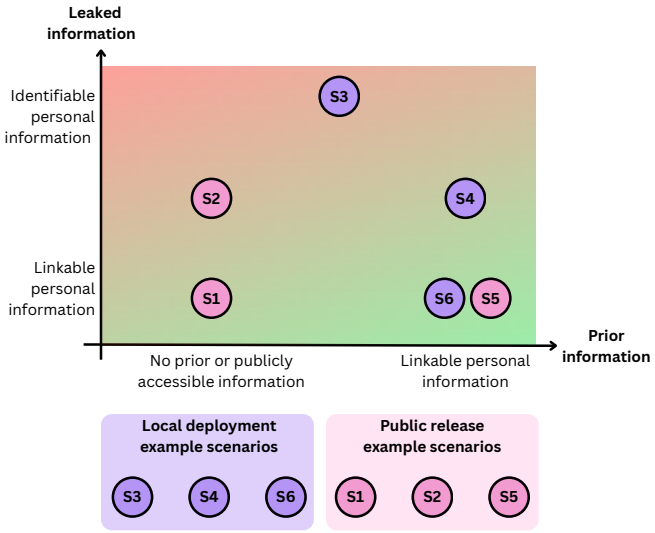
Axis I - Prior information

The first axis captures the amount and type of prior information required for leakage to occur during inference. This dimension is important for clinical risk assessment because the same technical vulnerability can imply very different real-world harms.

- *No prior information or publicly accessible information:* At the lowest barrier, publicly obtainable information, such as public records, social media traces, or casual observation (e.g., visible health status) which may be non-medical, would enable leakage. A related scenario in this tier is unconditional generation, where the prompt does not start from a specific patient profile but instead probes the model to elicit memorized training content or population-level information. Unconditional generative models may memorize and reproduce training examples such as medical images, and carefully crafted prompts can sometimes extract snippets of real data or highly specific clinical patterns even from anonymized models [Dar et al., 2025]. This risk is especially salient as synthetic data cohorts are



(a) **Foundation model development and release workflow.** De-identified patient data from multiple institutions (e.g., hospitals) is used to pre-train a foundation model (left). For this model, two deployment pathways are shown: (i) Local deployment, where the foundation model is fine-tuned by a healthcare institution or a third-party business to be securely deployed within a hospital, or (ii) public release of the model as open weights or an interface for general users. All stakeholders are assumed to operate within applicable legal frameworks, such as HIPAA, GDPR, and the EU AI Act.



	Description
Identifiable personal information	Information that directly identifies a person or can reasonably be linked to them. This includes protected health information and other personal data covered by privacy laws (GDPR/HIPAA).
Linkable personal information	Individual-level information that may become identifying, or privacy-sensitive, when combined with other available information.
Publicly accessible information	Information shared or observable online (social posts, photos, location check-ins/GPS traces, forum comments).

(b) **Two-dimensional privacy risk framework for model-based data leakage.** The framework characterizes privacy risk of data leakage along two orthogonal axes. Axis 1 (x-axis: Prior information) captures what information is required to extract information from a model, ranging from no personal or public information (e.g., demographics, unlinked social media traces) to linkable personal information (e.g. medications, diagnoses). Axis 2 (y-axis: Leaked information) captures what type of information can be extracted from the model, progressing from linkable personal information to identifiable personal information.

Figure 1: Overview of the deployment workflow and privacy risk framework.

increasingly promoted as privacy-preserving alternatives for data sharing [Stadler et al., 2022, Yoon et al., 2023, Sarkar et al., 2024].

- *Linkable personal information:* Leakage events in this tier require access to some information that is linked to an individual. This category is practically important in real clinical environments, where a user may have access to a medication list, a single diagnostic test, or a clinical narrative from a referral note. In such cases, the privacy risk arises from the model's ability to infer additional sensitive details from these partial inputs, instead of information already held by the user. Generative and multimodal foundation models can use sparse cues, such as a medical image or partial medication regimen, and elicit further details such as comorbidities, hospitalization patterns, or rare diagnoses. The key point is that the input may be non-identifying, while still enabling disclosure of sensitive information through model inference or synthesis.

Axis II - Leaked information

Along the second axis, we categorize what type of information can be extracted from a medical foundation model. This distinction matters because different leakage modes translate into different clinical and social harms. Some disclosures are largely reputational or administrative, while others can expose diagnoses, treatments, or highly identifying clinical narratives specific to an individual. Legal definitions of personal data distinguish between information whose processing is subject to data protection law and information that falls outside the scope of that law.

Central to this distinction is whether an individual can be considered identifiable from the data, which determines how their processing is covered by the law [Cobbe, 2026].

We group information leakage into two categories:

- *Linkable personal information:* This category is similar to the definition in Axis I, but applied to a model leaking this information rather than an individual previously knowing it. Even when foundation models are trained on de-identified data, reconstruction of those de-identified records is possible [Packhäuser et al., 2022]. However, on its own, leakage of an isolated de-identified piece of information poses a low risk, e.g., a generative model producing a replica of a patient's de-identified medical image. The risk is introduced by linkability to other external information, where de-identified data may be combined with (quasi-)identifiers or external data to increase privacy risk [Jeong et al., 2026, Stadler et al., 2022]. In a model-mediated leakage setting, reidentification risk with de-identified data is amplified with additive sources [Hallaj et al., 2026]. For instance, in the generative model example, if it is also known that the model was trained on a cohort restricted to a specific condition (e.g., a rare genetic disease registry) [Kehl et al., 2024], membership reveals diagnosis.
- *Identifiable personal information:* This includes any personal information that could render an individual identifiable, including data elements commonly removed during de-identification (name, address, etc.), which are discussed in greater detail in the next section on legal considerations. For instance, generative models introduce an additional leakage pathway by directly synthesizing private training data50 and may synthesize memorized fragments of private training data, either verbatim or in near-verbatim form.

This two-axis framework helps us locate data leakage in a practical, contextual risk space and is designed to focus on cases where the sensitivity of the leaked data is higher than the required prior information. There are other possible marginal privacy loss scenarios. For instance, in many membership-inference settings, the user already holds a patient's full (or near-full) record and queries the model only to determine whether it was used in training. In such cases, the key question is what additional information the model reveals beyond the prior knowledge, and which actors could plausibly obtain that starting point. Other factors, such as model architecture, scale, and training procedures, further affect leakage possibility, shaping the risk that sensitive medical details could be reproduced or inferred in real-world healthcare use [Carlini et al., 2022].

Whether such leakage triggers legal obligations depends on whether the revealed information qualifies as personal data under applicable law. We therefore examine how these leakage mechanisms intersect with existing legal frameworks in the United States and the European Union.

4 Legal Landscape

In the United States, the HIPAA Privacy Rule is the federal law that governs when certain forms of protected health information (PHI) may be shared. For reasons we explain, it places only limited constraints relevant to the case studies we discuss.

At the threshold, it applies only to "covered entities" and their "business associates." A covered entity is "(1) A health plan[,] (2) A health care clearinghouse [, or] (3) A health care provider who transmits any health information

in electronic form in connection with a transaction covered by this subchapter." 45 C.F.R. § 160.103. A business associate includes: "(i) A Health Information Organization, E–prescribing Gateway, or other person that provides data transmission services with respect to protected health information to a covered entity and that requires access on a routine basis to such protected health information. (ii) A person that offers a personal health record to one or more individuals on behalf of a covered entity. (iii) A subcontractor that creates, receives, maintains, or transmits protected health information on behalf of the business associate." 45 C.F.R. § 160.103. This means that if the information is generated by someone other than a covered entity (e.g., fitbit) and does not leave the covered entity (e.g., AI developed within a hospital system and deployed only within that hospital system) or is shared with a business associate pursuant to the kind of business associate agreements recognized by HIPAA, there is no HIPAA problem.

Second, HIPAA applies only to Protected Health Information (PHI), which is defined to mean "individually identifiable health information" (IIHI), which in turn is defined as: "information that is a subset of health information, including demographic information collected from an individual, and: (1) Is created or received by a health care provider, health plan, employer, or health care clearinghouse; and (2) Relates to the past, present, or future physical or mental health or condition of an individual; the provision of health care to an individual; or the past, present, or future payment for the provision of health care to an individual; and (i) That identifies the individual; or (ii) With respect to which there is a reasonable basis to believe the information can be used to identify the individual." 45 C.F.R. § 160.103 If the information shared to train a model does not meet this definition, then HIPAA does not prevent a covered entity from sharing it to train a model.

Third, HIPAA specifies that "[h]ealth information that does not identify an individual and with respect to which there is no reasonable basis to believe that the information can be used to identify an individual is not individually identifiable health information." 45 C.F.R. § 164.514. More specifically, it provides two methods by which data can meet that requirement. The first is the so-called "expert determination" pathway, in which a "person with appropriate knowledge of and experience with generally accepted statistical and scientific principles and methods for rendering information not individually identifiable.(i) Applying such principles and methods, determines that the risk is very small that the information could be used, alone or in combination with other reasonably available information, by an anticipated recipient to identify an individual who is a subject of the information; and (ii) Documents the methods and results of the analysis that justify such determination." 45 C.F.R. § 164.514. This method is not commonly used, but the examples we discuss in this paper raise the question of under what circumstances an expert could make the necessary determination, given the increased data leakage risks. Second, and more commonly used, HIPAA specifies that information ceases to be individually identifiable health information if 18 categories of identifiers are stripped before sharing. 45 C.F.R. § 164.514. In the EU, the GDPR applies to any processing of personal data, including model training and deployment24, where personal data means "any information relating to an identified or identifiable person" (Art. 4(1)). Whether de-identified data qualifies as "identifiable" under the GDPR depends on the risk of re-identification. Recent jurisprudence from the European Court of Justice (see Appendix 7) clarifies that this assessment must be made from the perspective of the relevant controller or recipient. The analysis considers the means reasonably available to that entity to re-identify the data. Truly anonymized data falls outside the GDPR, whereas pseudonymized data generally remains within scope. Personal health data constitute a special category of personal data whose processing requires a lawful basis and specific justification, and EU member states may impose additional processing restrictions (Art. 9). Where personal data may appear in training data, prompts, and logs, adherence to data-protection principles such as purpose limitation, data minimization, transparency, and security must be ensured [Bodnari and Travis, 2025]. The GDPR also describes roles that determine the legal responsibilities of various parties (Table 2). The naming depends on the actual influence over purpose and means, not contractual labels. This means that a vendor called a "processor" may become a "joint controller" if it meaningfully influences model architecture or secondary use.

The EU AI Act (AIA) introduces tiered obligations based on application risk at the level of AI models and AI systems, including for general-purpose AI (GPAI)53. AI systems that require a third-party conformity assessment according to the Medical Device Regulation (MDR), i.e., systems such as medical AI software assigned class IIa or higher under the MDR, are automatically high-risk systems under the AIA (Annex I Section A No. 11 AIA). Other elements of the EU regulatory ecosystem are listed in Appendix 7. Beyond statutory privacy regimes in the US and EU, model development and deployment are shaped by a broader governance ecosystem that includes contracts, institutional oversight, technical standards (e.g., ISO/IEC), case law, and regulatory guidance. While formal law carries binding force but evolves slowly, guidance and standards can adapt more quickly, though they may differ across jurisdictions and lack uniform enforcement.

Data and model governance also rely on contracts and institutional controls that vary across the development pipeline [Morley et al., 2022, Davis et al., 2025]. Where foundation model development qualifies as human subject research under applicable regulations, activities may be within the scope of institutional review board (IRB) oversight and data use agreement [Spector-Bagdady et al., 2023]. However, regulatory requirements differ across jurisdictions. In many EU member states, secondary use of health data does not necessarily require approval from a research ethics

Table 1: Description of GDPR roles for responsibility in protecting patient privacy.

Role	Legal Definition (GDPR)	Example
Controller: Decides why and how data are processed	"Natural or legal person, public authority, agency or other body which determines the purposes and means of processing personal data" (Art. 4(7)).	Hospitals that train a model or health-tech companies collecting clinical data from multiple hospitals to build a diagnostic AI system.
Joint Controllers: Two entities decide together	"Two or more controllers jointly determine the purposes and means of processing and must transparently allocate responsibilities between them" (Art. 26).	Hospital–company co-development of a foundation model fine-tuned on hospital data or a multi-hospital consortium developing a shared model.
Processor: Acts on behalf of the controller/covered entity	"Natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller" (Art. 4(8)).	Cloud providers, external machine learning contractors, or SaaS EHR vendors processing hospital data to train or host models.

committee (REC), and the applicable GDPR legal basis for data preprocessing remains inconsistently interpreted across regulators and other institutions [Smit et al., 2024, European Commission, 2021]. However, many foundation model projects, particularly those relying on retrospectively collected or de-identified hospital datasets shared with third-party developers, are structured as secondary data use or product development activities and may fall outside formal IRB review [Allen et al., 2014]. In such cases, governance is primarily contractually agreed on rather than regulatory. This landscape may evolve with the upcoming European Health Data Space (EHDS) regulation, which is expected to introduce permit-based access mechanisms for secondary use of health data, although implementation details are still emerging [European Data Protection Board and European Data Protection Supervisor, 2026, Becker and Dove, 2026]. Governance requirements also vary depending on whether models are vendor-built, co-developed, or developed internally62. At model release, oversight often shifts toward licensing terms, which may restrict re-identification or sensitive inference [Jungkunz et al., 2021].

5 Risk analysis case studies

Decision makers can use the two-axis framework to compare privacy risk across realistic deployment and use scenarios by jointly considering how sensitive the potential leakage is and how plausible it is that the necessary prior information would be available or obtainable in that context. This operational view supports scenario-specific governance: the same model behavior may imply very different risks depending on who can query the model, what auxiliary data are accessible, and what controls constrain use. With this framing, in this section, we present various leakage scenarios and analyze their risks along our two dimensions. These scenarios are summarized in Table 2 and Figure 2, and are positioned within our two-axis risk space in Figure 1b.

Each row in Figure 2 presents an example scenario of data leakage that belongs to the different deployment pathway depicted in Figure 1, and is color-coded to show what use-case the example belongs to, i.e., controlled clinical deployment (purple) or public release (pink). The "intended use" defines the purpose, which shapes regulatory obligations. The "training data" clarifies what kinds of data were used, affecting whether personal or special-category data are involved. The "privacy risk analysis" details the risk associated with data leakage as a function of the prior information. Finally, "GDPR/AIA Risk Analysis" identifies the potential lawful grounds in GDPR (roles explained in Table 1) for each specific scenario.

For the case studies in this paper, with one caveat, so long as the covered entity strips all these identifiers before sharing, HIPAA would not be violated in using this data to train a model. The caveat is that HIPAA treats the stripping of identifiers as sufficient if and only if "[t]he covered entity does not have actual knowledge that the information could be used alone or in combination with other information to identify an individual who is a subject of the information." 45 C.F.R. § 164.514. The meaning of this language has not received much elaboration by the U.S. Department of Health and Human Services (HHS) nor by scholars. The kind of data leakage we discuss in this paper may provide covered entities "actual knowledge" about the way "in combination with other information, could be used "to identify an individual," but this is uncertain. There is also a provision allowing the stripping of some but not all identifiers to form a "limited data set [...] if the covered entity enters into a data use agreement with the limited data set recipient in the way set out by HIPAA.

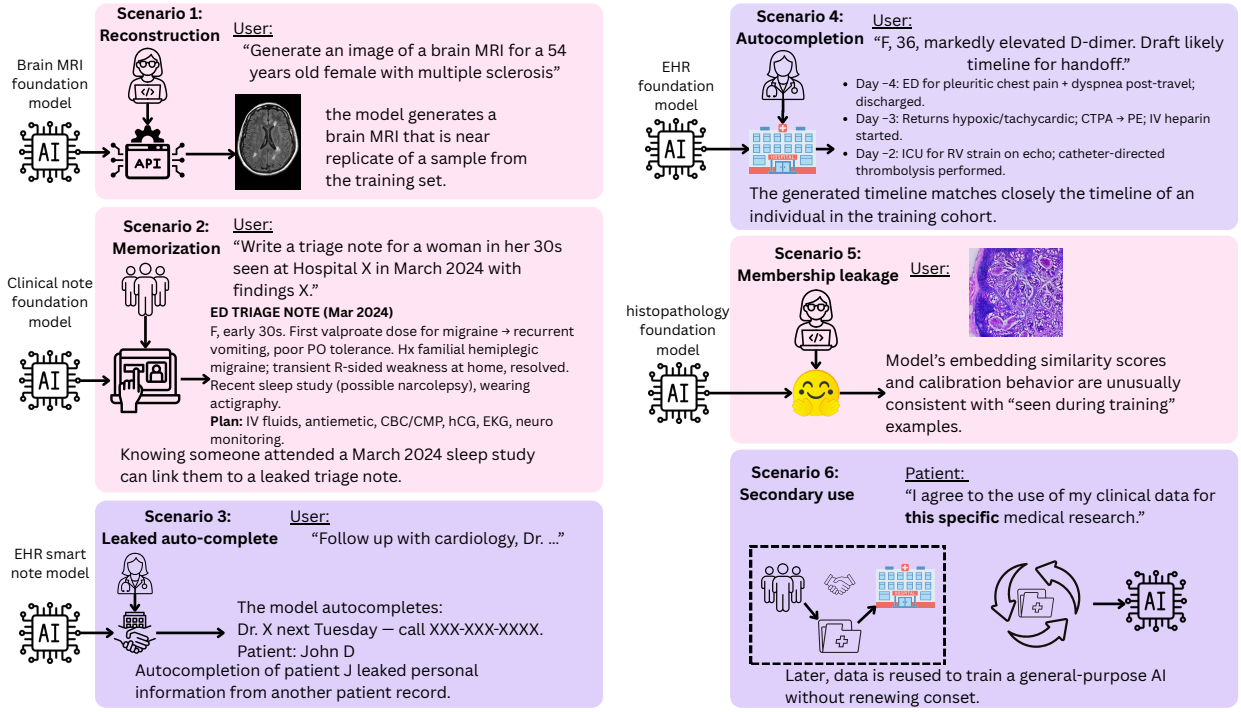


Figure 2: Privacy leakage scenarios across deployment pathways. Illustrative examples of the six scenarios described in Table 2, spanning common deployment pathways for healthcare foundation models. Panels are grouped by deployment setting (pink: public release; purple: local/hospital deployment) and highlight distinct release/deployment routes within each setting, including releasing an API (S1), releasing a web interface (S2), deploying a third-party model within a hospital environment (S3), using a locally fine-tuned hospital model (S4), and public release of model weights (S5). Data originally consented for clinical research are later reused to train a general-purpose AI system without renewed consent (S6).

Table 2: Example scenarios of data leakage across various deployment pathways.

Example scenarios	
S1 - Reconstruction: A company releases a brain-MRI generator model (as an API or open weights), that takes a short prompt like: "Generate an axial T1 brain MRI with mild motion artifact." Training data included de-identified MRIs from EU hospitals or EU patients. During routine use, a user requests a handful of images with similarly generic prompts (no patient name, age, or identifiers). One generated image is a near-replica of a real scan from a training individual. The replica preserves distinctive anatomy and pathological patterns that could enable re-identification.	**Intended use:** Image generation for research or educational purposes, not to reproduce real patient scans. **Training data:** De-identified brain-MRI images. **Privacy risk analysis:** A single leaked MRI contains limited information in isolation. Risk increases if the image can be linked to auxiliary information about the training cohort (e.g., that the model was trained on MRIs from Hospital X's tumor clinic), and especially if membership inference confirms that a specific person's scan was included. **GDPR/AIA Risk Analysis:** The entity that trains and releases the model acts as the **controller** for the training data and must ensure lawful processing and effective safeguards against memorization. If a separate provider deploys the model via API, it may qualify as an additional **controller** for outputs. Downstream users are typically recipients unless they further process or redistribute data. <u>GDPR</u> Art. 5(1)(f) – integrity and confidentiality Art. 25 – data protection by design Art. 32 – security safeguards Art. 9 MRI Health data → special category Even "de-identified" MRIs can be personal data if linkage is reasonably possible (Recital 26) (as discussed in Section 5). <u>AI Act:</u> GPAI / generative models must document training sources and mitigate memorization risk, but the Act does not define when outputs become personal data.
S2 - Memorization: A company offers a public user interface for clinical-note generation. A user provides a prompt like: "Write an example triage note for a woman in her 30s seen at Hospital X in March 2024 with findings X/Y/Z." The patient has posted online clues (a sleep-lab photo, hospital location, distinctive symptoms). The model returns text closely matching a real training note, releasing sensitive information the person from the training cohort never shared publicly.	**Intended use:** Clinical note drafting support, not reproducing real patient histories. **Training data:** De-identified triage chats and clinical notes. **Privacy risk analysis:** A single generated note may not contain direct identifiers, yet risk arises when outputs can be linked to external context. For example, combining model output with publicly available clues (such as a patient posting about participation in a sleep study) may enable attribution and reveal additional sensitive information, including training-set membership. Near-verbatim reproduction is consistent with documented evidence that LLMs can memorize and reproduce training data under certain prompts. **GDPR/AIA Risk Analysis:** The company training and offering the API acts as **controller** for training and deployment and must ensure that de-identification and safeguards are effective. Contractual or research-use permissions do not override GDPR obligations if outputs are personal data. <u>GDPR</u> Art. 5(1)(f) – integrity and confidentiality Art. 25 – data protection by design Art. 32 – security safeguards Art. 9 Health data → special category The legal implications depend on whether the output becomes identifiable in context (see Section 5).

Example scenarios	
S3 - Leaked autocompletion: A hospital purchases an EHR "smart note" model from a third-party company that clinicians can use the LLM to draft a patient summary. The model was fine-tuned on past discharge summaries that still contained identifiers. While writing Patient A's discharge note, the clinician types: "Follow up with cardiology, Dr. …" and accepts an autocomplete suggestion. The model inserts a line copied from a different training example: "Follow up with Dr. X next Tuesday — call 416-XXX-XXXX. Patient: John D." which belongs to Patient B. That PHI is now mistakenly placed into Patient A's chart.	**Intended use:** The LLM supports discharge summary drafting for patients. **Training data:** Trained on de-identified patient notes and finetuned on identifiable discharge summaries from the hospital. **Privacy risk analysis:** The incident covers a disclosure of PHI as the model reproduces identifiers from training data. This leakage stems from model behaviors under normal use, rather than unauthorized access. **GDPR/AIA Risk Analysis:** The hospital, as the data **controller** and model deployer, remains responsible for preventing such disclosures through appropriate safeguards, regardless of whether fine-tuning was internal or outsourced. Vendors involved in model training or hosting share **processor** or **joint controller** obligations. GDPR Art. 5(1)(f) – integrity and confidentiality Art. 9 – special-category data disclosure Art. 25 – insufficient privacy-by-design Art. 32 – inadequate safeguards Art. 33/34 – potential breach notification AI Act High-risk clinical systems require risk management and human oversight but do not define reconstruction thresholds.
S4 - Autocompletion: A hospital deploys an EHR foundation model as a documentation assistant within a patient chart. The system receives structured context (demographics, recent lab results, medication list and prior notes) and autogenerates a draft summary for clinical handoff. *draft the likely recent timeline to support handoff*"). A rare case (female with markedly elevated D-dimer and atypical coagulation markers) the model generates a highly specific narrative including an uncommon diagnostic pathway and medication regimen. Although framed as a probabilistic completion, the rare combination of features and highly specific management steps may mirror a distinctive historical case from the training data.	**Intended use:** Clinical tool for context completion, not retrieval of real patient histories. **Training data:** Trained on de-identified patient notes and finetuned on identifiable discharge summaries from the hospital. **Privacy risk analysis:** If the completion stays at the level of common clinical reasoning (e.g., "consider PE workup"), privacy risk is low. However, rare or low-frequency combinations of diagnosis steps, or medication dosing patterns can render the output record-like and plausibly attributable to a specific individual. At that point, the risk shifts from a generic inference to plausible reconstruction. **GDPR/AIA Risk Analysis:** Where the hospital determines the purpose and means of deployment, it acts as **controller**. The developer may qualify as **processor** or **joint controller**, depending on its influence over training and system design. Both must ensure safeguards against reconstruction and memorization. GDPR Art. 5(1)(f) – integrity and confidentiality Art. 25 – data protection by design Art. 32 – security safeguards Art. 9 Health data → special category Art. 33–34 Could trigger breach notification. Art. 4(2) Reconstruction = processing/disclosure of personal data AI Act High-risk clinical systems require risk management and human oversight but do not define reconstruction thresholds.

Table 2: Example scenarios of data leakage across various deployment pathways (continued).

Example scenarios	
S5 - Membership leakage: To assess how training data influences model behavior, a researcher probes a publicly released histopathology foundation model trained on a breast cancer cohort. Using a de-identified digital slide patch from a known patient, they observe that the model's embedding similarity scores and calibration behavior are unusually consistent with "seen during training" examples compared to matched controls. Even without revealing the patient's label or reproducing any identifiable image content, the interaction can support inference that this individual's specimen was part of the training cohort.	**Intended use:** Clinical language support, not confirmation of dataset. **Training data:** Trained on de-identified patient data. **Privacy risk analysis:** A membership signal does not reveal full records but indicates that a person's data was used for model training. In health care, inclusion alone may reveal sensitive facts, especially where the cohort is condition-specific (e.g., cancer patients). Membership can therefore amount to disclosure of special-category data. **GDPR/AIA Risk Analysis:** The model provider acts as **controller** for training and deployment decisions and must mitigate such risks. API deployers share responsibility if their system exposes signals that enable inference. Users performing tests are typically recipients unless they systematically collect or publish results. GDPR Art. 5(1)(f) – integrity and confidentiality Art. 25 – data protection by design Art. 32 – security safeguards Art. 9 Health data → special category As noted above, identifiability under GDPR is assessed relative to the actor's capabilities and accessible auxiliary information. AI Act The AI Act requires risk mitigation for sensitive-data memorization but does not address membership inference explicitly.
S6 - Secondary use: Patients at Hospital X consent to their clinical data being used for medical research. Years later, the hospital (or a partner institution) contributed a large corpus of historical EHR notes and imaging data to a foundation-model pretraining dataset. The resulting model is used for broad clinical and commercial applications, including deployment by third parties. Patients were never explicitly informed that their data might be used to train general-purpose AI systems or commercial foundation models. Some patients later withdraw consent, but their data have already influenced the model's weights.	**Intended use:** Original: medical research Later: general-purpose model development and downstream deployment. **Training data:** De-identified patient data. **Privacy risk analysis:** This scenario covers a purpose drift rather than a direct disclosure: data are reused beyond what patients reasonably expected. Once embedded in model weights, data are difficult to remove, creating tension with erasure rights. **GDPR/AIA Risk Analysis:** The hospital, as **controller** and must ensure lawful secondary use and compatibility with the original purpose. Developers may qualify as controllers or joint controllers if they define training objectives. Responsibility centers on ensuring valid legal bases, transparency, and safeguards before reuse. GDPR Art. 5(1)(b) – purpose limitation Art. 17 – right to erasure Art. 9 Health data → special category Art. 6(4) permits secondary research use with safeguards and requires compatibility assessment Consent limits: Recital 33 allows broad consent but not unlimited future use. Transparency obligations (Art. 13–14). AI Act The AI Act requires data governance and documentation but does not resolve issues related to consent scope or machine unlearning.

Note, the scenarios in Table 2 describe AI systems used to provide information for clinical decision-making, such as diagnosis, risk stratification, or treatment planning. When intended for such purposes, they qualify as medical device software under Rule 11 of Annex VIII to the EU Medical Device Regulation and are consequently classified as high-risk AI systems under Annex I Section A of the EU AI Act (more details see Section 4). Across frameworks, privacy law does not define quantitative thresholds for memorization, reconstruction, or membership inference. This technology-neutral design is understandable, but it creates uncertainty when evaluating whether a model remains effectively anonymized or legally compliant. Throughout the scenarios, this gap recurs: legal obligations attach to disclosure of personal data, yet models may reveal probabilistic or fragmentary signals that fall short of explicit record release.

Taken together, these scenarios illustrate how privacy risks can arise across different stages of the foundation model lifecycle and deployment settings. Next, we therefore outline technical and legal mitigation strategies that can reduce these risks at different points in the pipeline.

6 Mitigating Privacy Risks

Privacy risks in medical foundation models arise across the full lifecycle, from data collection and curation to model development. They therefore cannot be addressed with a single safeguard at one point in the pipeline. Effective mitigation requires coordinated legal and technical measures throughout the lifecycle. The two-axis framework also helps clarify how to prioritize these measures. Scenarios involving more sensitive leakage and requiring little prior information demand stronger safeguards. Mitigation should thus be calibrated both to the lifecycle stage and to a contextual risk space. Below, we discuss these mitigation strategies at the various levels of model development.

Data collection

Legal frameworks such as the GDPR and HIPAA emphasize some combination of lawful basis, purpose limitation, data minimization, and de-identification or pseudonymization as primary safeguards [Morley et al., 2022, Yang et al., 2025]. These requirements are largely formulated around the release and sharing of datasets, rather than downstream model behavior. As mentioned earlier, HIPAA applies only to PHI that identifies the individual, or with respect to which there is a reasonable basis to believe the information can be used to identify the individual. If the information shared to train a model does not meet this definition, then HIPAA does not prevent a covered entity from sharing it to train a model. HIPAA also puts in place a general "minimum necessary" constraint, that a covered entity "must make reasonable efforts to limit protected health information to the minimum necessary to accomplish the intended purpose of the use, disclosure, or request." 45 C.F.R. § 164.502. This requirement would govern any sharing of data by a covered entity. There is also a provision allowing the stripping of some but not all identifiers to form a "limited data set [...] if the covered entity enters into a data use agreement with the limited data set recipient" in the way set out by HIPAA.

Recent regulatory and policy developments reflect growing interest in enabling secondary data use while managing privacy risk, including proposals for decentralized architectures such as federated personal health data spaces that keep individuals "in the loop" while still supporting large-scale health data use [Raab et al., 2023]. Parallel initiatives, such as the AI Act's risk-based classification of medical AI, the EHDS and Data Act frameworks, and the Commission's Digital Omnibus proposal, further signal a shift toward facilitating data sharing and AI training through permits, opt-outs, and contractual mechanisms. Recently, the French DPA (CNIL) shared a decision aid regarding when a model should be considered anonymous, meaning outside the scope of the GDPR [Commission Nationale de l'Informatique et des Libertés (CNIL), 2026]. Taken together, these developments suggest a broader move away from strict consent-based models and absolute notions of personal data toward tiered, context-dependent privacy protections, motivating dynamic risk assessments aligned with practical leakage scenarios.

Practical steps at the data curation stage can reduce downstream leakage risk. Variability in de-identification practices, underlying data distributions, and dataset sizes may additionally introduce privacy risks. For example, if one site de-identifies through reversible pseudonymization, such as "hidden in plain sight" while another site uses anonymization through masking, these differences may result in uneven privacy guarantees across contributors and enable source inference attacks [Hu et al., 2021]. Increasing dataset size and diversity is an effective mitigation and reduces the likelihood that rare samples dominate leakage positions high on axis II in Figure 1b. Generative models exhibit stronger memorization when trained on smaller or homogeneous datasets [Gu et al., 2023], whereas larger and diverse datasets promote generalization. Memorization and extractability are often concentrated on rare samples, where low-frequency patterns are more likely to be reproduced under targeted prompting [Kulynych et al., 2022]. Constructing large, heterogeneous, multi-institutional cohorts can therefore dilute exposure to any individual record and reduce the feasibility of linkage-based identification in practice.

Model development

Modern privacy frameworks and guidance emphasize risk management and data protection by design, but offer limited guidance on privacy harms arising from model behavior rather than explicit data disclosure. This creates a compliance gap: standards such as ISO/IEC 42001:2023 require "appropriate" safeguards, yet do not specify what constitutes actionable leakage, what evidence is sufficient to demonstrate safety, or when remediation is mandatory. In the U.S., outside HIPAA-covered entities and business associates, there is often no general restriction on using health-related data for model training. Still, privacy-violating outputs may expose developers to common-law privacy claims, an area that remains underdeveloped.

In practice, these obligations are operationalized through privacy-specific evaluations and defenses. Leakage auditing, including membership inference, extraction tests, canary exposure, and structured red-teaming, has become a common practice [Tonekaboni et al., 2025, Perez et al., 2022, Meeus et al., 2025, Purpura et al., 2025]. Developers also deploy alignment and safety layers [Li et al., 2024] to filter sensitive generations before release. Differential privacy (DP) [Dwork and Roth, 2014] provides formal bounds on information leakage and has been shown to reduce membership inference and reconstruction risks in health and deep learning settings [Abadi et al., 2016, McMahan et al., 2018]. DP primarily reduces vertical movement on axis II in Figure 1b and limits how much new personal information the model can reveal, regardless of prior knowledge. Other approaches, such as hierarchical memories [Pouransari et al., 2026], or isolating memorization by design [Ghosal et al., 2025], further illustrate available technical controls.

Remediation remains under-specified. Although safety fine-tuning and targeted retraining are feasible, legal frameworks typically do not mandate ongoing post-training evaluation to verify that memorized content has been removed, nor do they define thresholds that trigger corrective action short of full record reconstruction. The result is a persistent gap between detecting leakage and enforcing mitigation, highlighting the need for concrete, testable criteria that link high-level legal duties to measurable model behavior.

Model deployment or release

At deployment, legal frameworks typically require appropriate technical and organizational safeguards to protect patient privacy, often implemented through licenses, terms of use, and access controls. In practice, however, privacy risk depends heavily on deployment format. Safeguards may include graduated access controls, rate limiting, logging, architectural separation between high-capability models and public interfaces, and monitoring for anomalous or extraction-like use. By contrast, unrestricted APIs, downloadable weights, or open fine-tuning interfaces enable model extraction, repurposing, and redistribution [Papernot et al., 2016] beyond the original governance context, potentially bypassing training-time safeguards, such as output filtering or privacy-preserving optimization.

U.S. tort law, which provides the ability to bring a claim against a wrongdoer after an injury occurs, is still developing in this area and it is not clear if it is likely to yield robust liability [De Bruyne and Van Leenhove, 2022, Noto La Diega and Bezerra, 2024]. Importantly, HIPAA does not provide patients a private right of action. That means patients may not themselves sue directly under the statute if their information is improperly shared – only HHS may bring such an action. However, several state courts have recognized state common law torts in instances where there is "unauthorized disclosure of confidential information obtained in the course of [a medical treatment] relationship," and have relied on HIPAA as informing the relevant standard of care. Byrne v. Avery Ctr. for Obstetrics & Gynecology, P.C., 327 Conn. 540 (2018). Private individuals may, in some instances, be able to bring such cases, though this case law is emerging, and the application to cases involving data leakage of the kind we discuss would be novel. When, due to leakage, identifiable information about a patient is revealed they may also be able to bring one of the so-called "privacy torts," most likely an action for "public disclosure of private facts" involving "(1) the public disclosure, (2) of a private fact, (3) that would be offensive and objectionable to a reasonable person, and (4) that is not of legitimate public concern." 103 Am. Jur. Proof of Facts 3d 159. We are not aware of any instance where this tort has been advanced in a case where generative AI produces true private facts about an individual due to leakage, so the theory is untested. Among the questions that courts might face is whether unintentional sharing counts for the tort or intentional action is required, and what kinds of injuries are cognizable, and the answers might vary by state. Even if plaintiffs are successful in suing model developers or implementers in such cases, common law judge-by-judge decision-making in these areas is unlikely to generate detailed guidance in the short term. Finally, beyond HIPAA, some states have additional privacy statutes that may further limit the sharing of data.

Technical mitigation continues after release. Post-deployment auditing, including canary insertion, targeted extraction probes, or memorization benchmarks, can detect reproduction of rare or sensitive records [Panda et al., 2025]. Maintenance mechanisms such as machine unlearning [Li et al., 2026] and periodic retraining offer a way to reduce memorization in response to new risks or regulatory requests. Policy discussions increasingly emphasize such layered monitoring [International AI Safety Report, 2026]. Recent EU reform proposals, including amendments to Article 9

GDPR in the Digital Omnibus package, if adopted, may introduce additional obligations for controllers. Where special-category personal data are identified in training datasets or models, controllers must remove them or, if removal would require disproportionate effort, effectively prevent their use in outputs or being disclosed85. While it remains unclear whether and in what form this approach will become binding law, it reflects a shift toward output-level containment where full deletion is technically infeasible.

7 Conclusion

Building on the deployment pathways, risk framework, and scenario analysis presented above, medical foundation models offer substantial potential for clinical decision support, screening, and public health, but their safe deployment requires privacy evaluation that goes beyond controlling inputs and access. Privacy risk in these systems is continuous rather than categorical. In this work, we introduce a structured, two-dimensional framework for assessing model-mediated privacy risk by jointly characterizing (i) the prior-knowledge threshold needed to elicit leakage and (ii) the type and extent of information that can be revealed. This framing provides a practical lens for comparing risk across deployment settings (e.g., controlled clinical use versus broader release), identifying plausible leakage pathways, and mapping them to targeted mitigation strategies and governance requirements. It helps align technical risk assessment with emerging regulatory expectations, particularly as health-related AI systems expand beyond traditional clinical settings. Although our focus is privacy leakage, these risks intersect with broader safety concerns such as bias propagation, misinformation, and downstream misuse, highlighting the need for lifecycle-aware evaluation rather than isolated technical safeguards.

At present, EU privacy law largely differentiates cases based on whether an individual is identifiable. Our framework suggests that privacy risk is more nuanced: harm may arise not only from clear identification, but also from the sensitivity of leaked information, the ease with which inferences can be drawn, or reconstruction-style outputs that resemble real records without directly naming a person. This raises a broader question for future work: whether privacy law should continue to rely so heavily on identifiability alone, or whether legal standards could evolve to better reflect gradations of inference, sensitivity, and probabilistic disclosure captured by a structured risk framework. The legal and regulatory landscape for AI remains in flux. A notable trend in the EU is the facilitation of AI training through expanded data-access and secondary-use provisions. While these developments may accelerate innovation, they also raise concerns about the erosion of privacy safeguards if protections do not evolve in parallel. How these regulatory trajectories unfold will play a key role in striking a balance between innovation, patient safety, and data protection.

Recent developments in U.S. health-data governance illustrate both expanding privacy protections and efforts to facilitate public-health data sharing. In particular, several states are introducing privacy rules that extend beyond the traditional scope of HIPAA. For example, California has strengthened protections for certain health-related and location data, such as restrictions on geofencing around health-care facilities, and expanded privacy obligations to entities outside HIPAA's coverage [California Department of Information Integrity, 2024, Alder, 2025]. At the same time, state privacy laws such as the CCPA generally exempt protected health information regulated under HIPAA, while still applying to other categories of personal data that fall outside HIPAA's definition88.

Finally, although our focus is individual-level privacy, model-mediated leakage can also generate collective harms, including profiling and differential treatment of groups [Bednarz et al., 2025]. Future work should examine how such risks propagate beyond individuals to affect populations and social systems. It should also analyze how legal roles under frameworks such as the GDPR and AI Act may shift in more complex settings, for example, in federated learning or fine-tuning arrangements.

Acknowledgment

Funding: The Eric and Wendy Schmidt Center at the Broad Institute of MIT and Harvard, Postdoctoral fellowship (ST). Wallenberg Foundation Scholarship Program for Postdoctoral studies at Massachusetts Institute of Technology and the Broad Institute (LS). Novo Nordisk Foundation Grant for a scientifically independent International Collaborative Bioscience Innovation & Law Programme (Inter-CeBIL Programme, grant number NNF23SA0087056) (IGC). The Weill Cancer Hub West Initiative (SR, EA). ELLIS Institute Finland (CC). National Science Foundation (NSF) 22-586 Faculty Early Career Development Award (no.2339381) (MG). The AI2050 Program at Schmidt Sciences (MG).

Author's contributions: Conceptualization: ST, LS, MG Supervision: MG, CC, EA, IGC Methodology: ST, LS, SR, CC, IGC, EA, MG Visualization: ST, LS Writing - original draft: ST, LS Writing - review & editing: ST, LS, SR, CC, IGC, EA, MG

Competing interests: IGC is a member of the Bayer Bioethics Council, a bioethics advisor for Bexorg, and an advisor for World Class Health and Manhattan Neuroscience LLP. He recently concluded service as the chair of the ethics advisory board for Illumina. He was also compensated for speaking at events organized by Philips with the Washington Post as well as the Doctors Company, attending the Transformational Therapeutics Leadership Forum organized by Galen Atlantica, and retained as an expert in health privacy, gender-affirming care, and reproductive technology lawsuits.

Data, code, and materials availability: No custom code, datasets, or unique materials were generated for this study. All information supporting the conclusions is contained in the manuscript.

References

Vikash Gupta, Barbaros Selnur Erdal, Carolina Ramirez, Ralf Floca, Laurence Jackson, Brad Genereaux, Sidney Bryson, Christopher P. Bridge, Jens Kleesiek, Felix Nensa, Rickmer Braren, Khaled Younis, Tobias Penzkofer, Andreas Michael Bucher, Ming Melvin Qin, Gigon Bae, Hyeonhoon Lee, M. Jorge Cardoso, Sebastien Ourselin, Eric Kerfoot, Rahul Choudhury, Richard D. White, Tessa Cook, David Bericat, Matthew Lungren, Risto Haukioja, and Haris Shuaib. Current state of community-driven radiological ai deployment in medical imaging. *JMIR AI*, 3: e55833, 2024.

Scott Mayer McKinney, Marcin Sieniek, Varun Godbole, Jonathan Godwin, Natasha Antropova, Hutan Ashrafian, Trevor Back, Mary Chesus, Greg S. Corrado, Ara Darzi, Mozziyar Etemadi, Florencia Garcia-Vicente, Fiona J. Gilbert, Mark Halling-Brown, Demis Hassabis, Sunny Jansen, Alan Karthikesalingam, Christopher J. Kelly, Dominic King, Joseph R. Ledsam, David Melnick, Hormuz Mostofi, Lily Peng, Joshua Jay Reicher, Bernardino Romera-Paredes, Richard Sidebottom, Mustafa Suleyman, Daniel Tse, Kenneth C. Young, Jeffrey De Fauw, and Shravya Shetty. International evaluation of an ai system for breast cancer screening. *Nature*, 577:89–94, 2020.

Nenad Tomašev, Xavier Glorot, Jack W. Rae, Michal Zielinski, Harry Askham, Andre Saraiva, Anne Mottram, Clemens Meyer, Suman Ravuri, Ivan Protsyuk, Alistair Connell, Cían O. Hughes, Alan Karthikesalingam, Julien Cornebise, Hugh Montgomery, Geraint Rees, Chris Laing, Clifton R. Baker, Kelly Peterson, Ruth Reeves, Demis Hassabis, Dominic King, Mustafa Suleyman, Trevor Back, Christopher Nielson, Joseph R. Ledsam, and Shakir Mohamed. A clinically applicable approach to continuous prediction of future acute kidney injury. *Nature*, 572:116–119, 2019.

Akhil Bhargava, Carlos López-Espina, Lee Schmalz, Shah Khan, Gregory L. Watson, Dennys Urdiales, Lincoln Updike, Niko Kurtzman, Alon Dagan, Amanda Doodlesack, Aimee Espinosa, Alexandra Halalau, Carmen DeMarco, Francisco Davila, Hugo Davila, Matthew Sims, Nicholas Maddens, Ramona Berghea, and Scott Smith. Fda-authorized ai/ml tool for sepsis prediction: Development and validation. *NEJM AI*, 2024. doi:10.1056/AIoa2400867.

Michael Moor, Oishi Banerjee, Zahra Shakeri Hossein Abad, Harlan M. Krumholz, Jure Leskovec, Eric J. Topol, and Pranav Rajpurkar. Foundation models for generalist medical artificial intelligence. *Nature*, 616:259–265, 2023.

Yih Chung Tham, Jocelyn Hui Lin Goh, and Dinah Zur. Building the world's first truly global medical foundation model. *Nature Medicine*, 31:3580–3585, 2025.

Yuting He, Fuxiang Huang, Xinrui Jiang, Yuxiang Nie, Minghao Wang, Jiguang Wang, and Hao Chen. Foundation model for advancing healthcare: Challenges, opportunities and future directions. *IEEE Reviews in Biomedical Engineering*, 18:172–191, 2025.

Kai Sun, Siyan Xue, Fuchun Sun, Haoran Sun, Yu Luo, Ling Wang, Siyuan Wang, Na Guo, Lei Liu, Tian Zhao, Xinzhou Wang, Lei Yang, Shuo Jin, Jun Yan, and Jiahong Dong. Medical multimodal foundation models in clinical diagnosis and treatment: Applications, challenges, and future directions. *Artificial Intelligence in Medicine*, 170:103265, 2025.

Kathleen Benitez and Bradley Malin. Evaluating re-identification risks with respect to the HIPAA privacy rule. *Journal of the American Medical Informatics Association*, 17(2):169–177, 2010.

Lin Lawrence Guo, Jason Fries, Ethan Steinberg, Scott Lanyon Fleming, Keith Morse, Catherine Aftandilian, Jose Posada, Nigam Shah, and Lillian Sung. A multi-center study on the adaptability of a shared foundation model for electronic health records. *npj Digital Medicine*, 7:171, 2024.

Andrew Sellergren, Sahar Kazemzadeh, Tiam Jaroensri, Atilla Kiraly, Madeleine Traverse, Timo Kohlberger, Shawn Xu, Fayaz Jamil, Cían Hughes, Charles Lau, Justin Chen, Fereshteh Mahvar, Liron Yatziv, Tiffany Chen, Bram Sterling, Stefanie Anna Baby, Susanna Maria Baby, Jeremy Lai, Samuel Schmidgall, Lu Yang, Kejia Chen, Per Bjornsson, Shashir Reddy, Ryan Brush, Kenneth Philbrick, Mercy Asiedu, Ines Mezerreg, Howard Hu, Howard Yang, Richa Tiwari, Sunny Jansen, Preeti Singh, Yun Liu, Shekoofeh Azizi, Aishwarya Kamath, Johan Ferret, Shreya Pathak, Nino Vieillard, Ramona Merhej, Sarah Perrin, Tatiana Matejovicova, Alexandre Ramé, Morgane Riviere, Louis Rouillard, Thomas Mesnard, Geoffrey Cideron, Jean-bastien Grill, Sabela Ramos, Edouard Yvinec, Michelle Casbon, Elena Buchatskaya, Jean-Baptiste Alayrac, Dmitry Lepikhin, Vlad Feinberg, Sebastian Borgeaud, Alek Andreev, Cassidy Hardin, Robert Dadashi, Léonard Hussenot, Armand Joulin, Olivier Bachem, Yossi Matias, Katherine Chou, Avinatan Hassidim, Kavi Goel, Clement Farabet, Joelle Barral, Tris Warkentin, Jonathon Shlens, David Fleet, Victor Cotruta, Omar Sanseviero, Gus Martins, Phoebe Kirk, Anand Rao, Shravya Shetty, David F. Steiner, Can Kirmizibayrak, Rory Pilgrim, Daniel Golden, and Lin Yang. Medgemma technical report. *arXiv preprint*, 2025. arXiv:2507.05201.

Lin Lawrence Guo, Ethan Steinberg, Scott Lanyon Fleming, Jose Posada, Joshua Lemmon, Stephen R. Pfohl, Nigam Shah, Jason Fries, and Lillian Sung. EHR foundation models improve robustness in the presence of temporal distribution shift. *Scientific Reports*, 13(1):3767, 2023.

Pawel Renc, Yugang Jia, Anthony E. Samir, Jaroslaw Was, Quanzheng Li, David W. Bates, and Arkadiusz Sitek. Zero shot health trajectory prediction using transformer. *npj Digital Medicine*, 7:256, 2024.

Google Research. Med-PaLM: A medical large language model. `https://sites.research.google/med-palm/`, 2022.

OpenAI. Introducing ChatGPT Health. `https://openai.com/index/introducing-chatgpt-health/`, January 2026.

Tianyu Han, Lisa C. Adams, Jens-Michalis Papaioannou, Paul Grundmann, Tom Oberhauser, Alexei Figueroa, Alexander Löser, Daniel Truhn, and Keno K. Bressem. MedAlpaca—an open-source collection of medical conversational AI models and training data. *arXiv preprint arXiv:2304.08247*, 2023.

Qianqian Xie, Qingyu Chen, Aokun Chen, Cheng Peng, Yan Hu, Fongci Lin, Xueqing Peng, Jimin Huang, Jeffrey Zhang, Vipina Keloth, and Xinyu Zhou. Me-LLaMA: Foundation large language models for medical applications. *Research Square*, 2024.

Nicholas Carlini, Chang Liu, Úlfar Erlingsson, Jernej Kos, and Dawn Song. The secret sharer: Evaluating and testing unintended memorization in neural networks. In *28th USENIX Security Symposium (USENIX Security 19)*, pages 267–284, 2019.

Urvashi Khandelwal, Omer Levy, Dan Jurafsky, Luke Zettlemoyer, and Mike Lewis. Generalization through memorization: Nearest neighbor language models. *arXiv preprint arXiv:1911.00172*, 2019.

Kushal Tirumala, Aram H. Markosyan, Luke Zettlemoyer, and Armen Aghajanyan. Memorization without overfitting: Analyzing the training dynamics of large language models. *Advances in Neural Information Processing Systems*, 35: 38274–38290, 2022.

U.S. Department of Health and Human Services, Office for Civil Rights. Breach report. OCR Portal, 2025. URL `https://ocrportal.hhs.gov/ocr/breach/breach_report.jsf`. Accessed 26 February 2026.

U.S. Department of Health and Human Services, Office of the Assistant Secretary for Planning and Evaluation. Health insurance portability and accountability act of 1996, 1996. URL `https://aspe.hhs.gov/reports/health-insurance-portability-accountability-act-1996`. Accessed 26 February 2026.

European Parliament and Council of the European Union. Regulation (EU) 2016/679 of the european parliament and of the council of 27 april 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing directive 95/46/EC (general data protection regulation). *Official Journal of the European Union*, L119:1–88, 2016.

Claudio Novelli, Federico Casolari, Philipp Hacker, Giorgio Spedicato, and Luciano Floridi. Generative AI in EU law: Liability, privacy, intellectual property, and cybersecurity. *Computer Law & Security Review*, 55:106066, 2024.

Isabel Barberá. AI privacy risks & mitigations – large language models (LLMs). European Data Protection Board Support Pool of Experts, April 2025. URL `https://www.edpb.europa.eu/system/files/2025-04/ai-privacy-risks-and-mitigations-in-llms.pdf`. Accessed 26 February 2026.

Nils Holzenberger and Winston Maxwell. A quantitative approach to the GDPR's anonymisation and "appropriate technical and organisational measures" tests. *Computer Law & Security Review*, 59:106173, 2025.

Qianqian Xie, Qingyu Chen, Aokun Chen, Cheng Peng, Yan Hu, Fongci Lin, Xueqing Peng, Jimin Huang, Jeffrey Zhang, Vipina Keloth, Xinyu Zhou, Lingfei Qian, Huan He, Dennis Shung, Lucila Ohno-Machado, Yonghui Wu, Hua Xu, and Jiang Bian. Medical foundation large language models for comprehensive text analysis and beyond. *npj Digital Medicine*, 8(1):141, 2025.

Xi Yang, Aokun Chen, Nima PourNejatian, Hoo Chang Shin, Kaleb E. Smith, Christopher Parisien, Colin Compas, Cheryl Martin, Anthony B. Costa, Mona G. Flores, Ying Zhang, Tanja Magoc, Christopher A. Harle, Gloria Lipori, Duane A. Mitchell, William R. Hogan, Elizabeth A. Shenkman, Jiang Bian, and Yonghui Wu. A large language model for electronic health records. *npj Digital Medicine*, 5(1):194, 2022.

Chaoyi Wu, Xiaoman Zhang, Ya Zhang, Hui Hui, Yanfeng Wang, and Weidi Xie. Towards generalist foundation model for radiology by leveraging web-scale 2D&3D medical data. *Nature Communications*, 16(1):7866, 2025.

Rahul Thapa, Magnus Ruud Kjaer, Bryan He, Ian Covert, IV Moore, Hyatt, Umaer Hanif, Gauri Ganjoo, M. Brandon Westover, Poul Jennum, Andreas Brink-Kjaer, Emmanuel Mignot, and James Zou. A multimodal sleep foundation model for disease prediction. *Nature Medicine*, 32:752–762, 2026.

Jun Li, Aaron D. Aguirre, Valdery Moura, Jiarui Jin, Che Liu, Lanhai Zhong, Chenxi Sun, Gari D. Clifford, M. Brandon Westover, and Shenda Hong. An electrocardiogram foundation model built on over 10 million recordings. *NEJM AI*, 2(7):AIoa2401033, 2025.

Won-Ki Jeong, Hyunwoo J. Kim, Zhongying Deng, Yiqing Shen, Angelica I. Aviles-Rivero, and Shaoting Zhang, editors. *Foundation Models for General Medical AI: Third International Workshop, MedAGI 2025, Held in Conjunction with MICCAI 2025, Daejeon, South Korea, September 27, 2025, Proceedings*, volume 16112 of *Lecture Notes in Computer Science*, 2026. Springer Cham.

Zofia Bednarz, Kelly Lewis, and Jathan Sadowski. 'it's not personal, it's strictly business': Behavioural insurance and the impacts of non-personal data on individuals, groups and societies. *Computer Law & Security Review*, 56:106096, 2025.

Hyeji Jun, Yutaro Tanaka, Shreya Johri, Sabrina Y. Camp, Erik L. Bao, Filipe L. F. Carvalho, Dan Y. Gui, Alexander C. Jordan, Chris Labaki, Samantha D. Martin, Matthew Nagy, Tess A. O'Meara, Theodora Pappa, Erica Maria Pimenta, Eddy Saad, David D. Yang, Riaz Gillani, Alok K. Tewari, Brendan Reardon, and Eliezer Van Allen. A context-augmented large language model for accurate precision oncology medicine recommendations. *Cancer Cell*, 2026.

Angelina Wang, Daniel E. Ho, and Sanmi Koyejo. The inadequacy of offline llm evaluations: A need to account for personalization in model behavior. *arXiv preprint arXiv:2509.19364*, 2025.

Syed Uzair Dar, Moritz Seyfarth, Ingo Ayx, Thomas Papavassiliu, Sören O. Schoenberg, Robert M. Siepmann, Franziska C. Laqua, Jan Kahmann, Norbert Frey, Bettina Baeßler, and Sebastian Foersch. Unconditional latent diffusion models memorize patient imaging data. *Nature Biomedical Engineering*, 2025.

Theresa Stadler, Bristena Oprisanu, and Carmela Troncoso. Synthetic data—anonymisation groundhog day. In *31st USENIX Security Symposium (USENIX Security 22)*, pages 1451–1468, 2022.

Jinsung Yoon, Michel Mizrahi, Nahid Farhady Ghalaty, Thomas Jarvinen, Ashwin S. Ravi, Peter Brune, Fanyu Kong, Dave Anderson, George Lee, Arie Meir, Farhana Bandukwala, Elli Kanal, Sercan Ö. Arık, and Tomas Pfister. Ehr-safe: generating high-fidelity and privacy-preserving synthetic electronic health records. *npj Digital Medicine*, 6 (1):141, 2023.

A. R. Sarkar, Yu-Sheng Chuang, Noman Mohammed, and Xiaoqian Jiang. De-identification is not enough: a comparison between de-identified and synthetic clinical notes. *Scientific Reports*, 14(1):29669, 2024.

Jennifer Cobbe. A relative mess: Identifying data subjects in multi-party processing. *Computer Law & Security Review*, 62:106362, 2026.

Kai Packhäuser, Daniel Schaub, Tobias Huber, Michael Pfeiffer, Gernot Schmidt, Jakob Nikolas Kather, Daniel Truhn, Peter Bruners, Tobias Penzkofer, Daniel Pinto dos Santos, Klaus Maier-Hein, and Bettina Baeßler. Deep learning-based patient re-identification is able to exploit the biometric nature of medical chest x-ray data. *Scientific Reports*, 12:1–13, 2022.

Shahin Hallaj, Anna Heinke, Fritz Gerald P Kalaw, Nayoon Gim, Marian Blazes, Julia Owen, Eamon Dysinger, Erik S Benton, Benjamin A Cordier, Nicholas G Evans, et al. Navigating open data sharing and privacy in the age of clinical ai research: from reidentification to pseudo-reidentification. *EClinicalMedicine*, 91, 2026.

Kenneth L. Kehl, Justin Jee, Karl Pichotta, Morgan A. Paul, Pavel Trukhanov, Christopher Fong, Michele Waters, Ziad Bakouny, Wenxin Xu, Toni K. Choueiri, Chelsea Nichols, Deborah Schrag, and Nikolaus Schultz. Shareable artificial intelligence to extract cancer outcomes from electronic health records for precision oncology research. *Nature Communications*, 15:9787, 2024.

Nicholas Carlini et al. Quantifying memorization across neural language models. *arXiv preprint arXiv:2202.07646*, 2022.

Andreea Bodnari and John Travis. Scaling enterprise ai in healthcare: The role of governance in risk mitigation frameworks. *npj Digital Medicine*, 8(1):272, 2025.

Jessica Morley, Louise Murphy, Aashima Mishra, Isha Joshi, and Konstantinos Karpathakis. Governing data and artificial intelligence for health care: Developing an international understanding. *JMIR Formative Research*, 6(1): e31623, 2022.

Heather A. Davis, Drew Kerkman, Amy A. Hoberg, Melissa Countryman, Whitney Beaver, Kevin Bybee, James M. Blum, and Brian M. Knosp. Establishing data governance for sharing and access to real-world data: A case study. *JAMIA Open*, 8(3):ooaf041, 2025.

Kayte Spector-Bagdady, Rebecca D. Pentz, Steven Joffe, Gail E. Henderson, Sharon L. R. Kardia, Jennifer Bollinger, Stephanie A. Kraft, Deven McGraw, Susan B. Trinidad, Benjamin S. Wilfond, Niraj H. Shah, Richard Platt, and Dan M. Roden. Principles for health information collection, sharing, and use: A policy statement from the american heart association. *Circulation*, 148:1061–1069, 2023.

Jeroen A. R. Smit, Monique Mostert, Rieke van der Graaf, Diederick E. Grobbee, and Johannes J. M. van Delden. Specific measures for data-intensive health research without consent: A systematic review of soft law instruments and academic literature. *European Journal of Human Genetics*, 32(1):21–30, 2024. doi:10.1038/s41431-023-01457-2. URL `https://doi.org/10.1038/s41431-023-01457-2`.

European Commission. *Assessment of the EU Member States' Rules on Health Data in the Light of the GDPR*. Publications Office of the European Union, Luxembourg, 2021. doi:10.2818/546193. URL `https://doi.org/10.2818/546193`.

Christina G. Allen, Terris R. Des Jardins, Anne Heider, Kevin A. Lyman, Jennifer McWilliams, Andy L. Rein, Amy A. Schachter, Sharon Silow-Carroll, Amy Wright, and Carol P. Friedman. Data governance and data sharing agreements for community-wide health information exchange: Lessons from the beacon communities. *eGEMs*, 2(1):1057, 2014.

European Data Protection Board and European Data Protection Supervisor. Edpb–edps joint opinion 2/2026 on the proposal for a regulation as regards the simplification of the digital legislative framework (digital omnibus), 2026. URL `https://www.edpb.europa.eu/system/files/2026-02/edpb_edps_jointopinion_202602_digitalomnibus_en.pdf`. Published 11 February 2026; accessed 26 February 2026.

Regina Becker and Edward S. Dove. The eu gdpr and secondary use of health and genetic data for research support purposes. *International Data Privacy Law*, 16(2):ipag001, 2026. doi:10.1093/idpl/ipag001. URL `https://doi.org/10.1093/idpl/ipag001`.

Miriam Jungkunz, Anne Köngeter, Kristin Mehlis, Eva C. Winkler, and Christoph Schickhardt. Secondary use of clinical data in data-gathering, non-interventional research or learning activities: Definition, types, and a framework for risk assessment. *Journal of Medical Internet Research*, 23:e26631, 2021.

Qifan Yang, Cristian Lepore, Jessica Eynard, and Romain Laborde. From theory to practice: Data minimisation and technical review of verifiable credentials under the gdpr. *Computer Law & Security Review*, 57:106138, 2025.

René Raab, Arne Küderle, Anastasiya Zakreuskaya, Ariel D Stern, Jochen Klucken, Georgios Kaissis, Daniel Rueckert, Susanne Boll, Roland Eils, Harald Wagener, et al. Federated electronic health records for the european health data space. *The Lancet Digital Health*, 5(11):e840–e847, 2023.

Commission Nationale de l'Informatique et des Libertés (CNIL). Analysing the status of an AI model with regard to the GDPR, 2026. URL `https://cnil.fr/fr/node/167980`. Accessed 12 February 2026.

Hongsheng Hu, Zoran Salcic, Lichao Sun, Gillian Dobbie, and Xuyun Zhang. Source inference attacks in federated learning. In *2021 IEEE International Conference on Data Mining (ICDM)*, pages 1102–1107. IEEE, 2021.

Xiang Gu, Chao Du, Tianyu Pang, Changyou Li, Min Lin, and Yisen Wang. On memorization in diffusion models. *arXiv preprint arXiv:2310.02664*, 2023.

Bogdan Kulynych, Mohammad Yaghini, Giovanni Cherubin, Michael Veale, and Carmela Troncoso. Disparate vulnerability to membership inference attacks. *Proceedings on Privacy Enhancing Technologies*, 2022(1):460–480, 2022. doi:10.2478/popets-2022-0023.

Sana Tonekaboni, Lena Stempfle, Ashkan Fallahpour, Walter Gerych, and Marzyeh Ghassemi. An investigation of memorization risk in healthcare foundation models. *arXiv preprint arXiv:2510.12950*, 2025.

Ethan Perez, Saffron Huang, Francis Song, Trevor Cai, Roman Ring, Jordan Aslanides, Amelia Glaese, Nathan McAleese, and Geoffrey Irving. Red teaming language models with language models, 2022. URL https://arxiv.org/abs/2202.03286.

Matteo Meeus, Lukas Wutschitz, Santiago Zanella-Béguelin, Shruti Tople, and Reza Shokri. The canary's echo: Auditing privacy risks of llm-generated synthetic text, 2025. URL https://arxiv.org/abs/2502.14921.

Alessio Purpura, Sparsh Wadhwa, Jack Zymet, Ananya Gupta, Andrew Luo, Mohammad K. Rad, Shreya Shinde, and Mohammad S. Sorower. Building safe genai applications: An end-to-end overview of red teaming for large language models. In *Proceedings of the 5th Workshop on Trustworthy Natural Language Processing (TrustNLP)*, pages 335–350. Association for Computational Linguistics, 2025. doi:10.18653/v1/2025.trustnlp-1.24. URL https://aclanthology.org/2025.trustnlp-1.24.

Shuo Li, Lan Yao, Lei Zhang, and Yang Li. Safety layers in aligned large language models: The key to llm security. *arXiv preprint arXiv:2408.17003*, 2024.

Cynthia Dwork and Aaron Roth. The algorithmic foundations of differential privacy. *Foundations and Trends in Theoretical Computer Science*, 9(3–4):211–407, 2014.

Martin Abadi, Andy Chu, Ian Goodfellow, H. Brendan McMahan, Ilya Mironov, Kunal Talwar, and Li Zhang. Deep learning with differential privacy. In *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*, pages 308–318. ACM, 2016.

H. Brendan McMahan, Daniel Ramage, Kunal Talwar, and Li Zhang. Learning differentially private recurrent language models. *International Conference on Learning Representations (ICLR)*, 2018.

Hadi Pouransari, David Grangier, C. Thomas, Michael Kirchhof, and Oncel Tuzel. Pretraining with hierarchical memories: Separating long-tail and common knowledge. In *International Conference on Learning Representations (ICLR)*, 2026.

Gaurav Rohit Ghosal, Pratyush Maini, and Aditi Raghunathan. Memorization sinks: Isolating memorization during llm training. In *Proceedings of the 42nd International Conference on Machine Learning*, volume 267 of *Proceedings of Machine Learning Research*, pages 19307–19326. PMLR, 2025.

Nicolas Papernot, Patrick McDaniel, and Ian Goodfellow. Transferability in machine learning: from phenomena to black-box attacks using adversarial samples. *arXiv preprint arXiv:1605.07277*, 2016.

Jan De Bruyne and Cedric Van Leenhove. Tort law and damage caused by ai systems. pages 395–445. 2022.

Guido Noto La Diega and Luiz Carlos Bezerra. Can there be responsible ai without ai liability? incentivizing generative ai safety through ex-post tort liability under the eu ai liability directive. *International Journal of Law and Information Technology*, 32(1):eaae021, 2024.

Ashwinee Panda, Xinyu Tang, Christopher Choquette-Choo, Milad Nasr, and Prateek Mittal. Privacy auditing of large language models. In *International Conference on Learning Representations*, volume 2025, pages 92555–92571, 2025.

Kemou Li, Qizhou Wang, Yue Wang, Fengpeng Li, Jun Liu, Bo Han, and Jiantao Zhou. Llm unlearning with llm beliefs. In *International Conference on Learning Representations*, volume 2026, pages 101587–101622, 2026.

International AI Safety Report. Second key update: Technical safeguards and risk management, 2026. URL https://internationalaisafetyreport.org/publication/second-key-update-technical-safeguards-and-risk-management. Accessed 26 February 2026.

California Department of Information Integrity. Federal and state health laws. https://www.cdii.ca.gov/compliance-and-policy/resources/federal-and-state-health-laws/, 2024. Accessed March 16, 2026.

Steve Alder. What is the ccpa hipaa exemption? https://www.hipaajournal.com/ccpa-hipaa-exemption/, March 2025. Accessed March 17, 2026.

European Parliament and Council of the European Union. Regulation (EU) 2023/2854 of the european parliament and of the council of 13 december 2023 on harmonised rules on fair access to and use of data and amending regulation (EU) 2017/2394 and directive (EU) 2020/1828 (data act). Official Journal of the European Union, 2023. URL https://eur-lex.europa.eu/eli/reg/2023/2854/oj/eng. Accessed 12 February 2026.

European Parliament and Council of the European Union. Regulation (EU) 2022/868 of the european parliament and of the council of 30 may 2022 on european data governance and amending regulation (EU) 2018/1724 (data governance

act). Official Journal of the European Union, 2022. URL https://eur-lex.europa.eu/eli/reg/2022/868/oj/eng. Accessed 12 February 2026.

European Parliament and Council of the European Union. Regulation (EU) 2025/327 of the european parliament and of the council of 11 february 2025 on the european health data space and amending directive 2011/24/EU and regulation (EU) 2024/2847. Official Journal of the European Union, 2025. URL https://eur-lex.europa.eu/eli/reg/2025/327/oj/eng. Accessed 12 February 2026.

European Commission. European artificial intelligence board (AI Board). Shaping Europe's Digital Future, 2026a. URL https://digital-strategy.ec.europa.eu/en/policies/ai-board. Accessed 12 February 2026.

European Commission. Medical Device Coordination Group (MDCG). Register of Commission Expert Groups, 2026b. URL https://ec.europa.eu/transparency/expert-groups-register/. Accessed 12 February 2026.

European Federation of Data Protection Officers (EFDPO). Comments on the european data protection board's guidelines 01/2021 on examples regarding data breach notification. Public consultation response, March 2021. URL https://www.edpb.europa.eu/system/files/documents/webform/public_consultation_reply/efdpo_position_examples_data_breaches-final.pdf. Accessed 12 February 2026.

Appendix A

As a reference for whether de-identified data is "identifiable", we can look at the recent jurisprudence by the European Court of Justice (Case C-413/23). In that case, the Court clarified that pseudonymised data is not automatically "personal data" for all parties. Rather, identifiability must be assessed relative to the specific actor and the technical and organisational measures in place. If a recipient does not possess, and is not reasonably likely to obtain, the additional information required for re-identification—because such access is technically prevented or legally prohibited—the data may, for that recipient, amount to effectively anonymous data. This reflects a modified relative interpretation of identifiability, under which the classification of data depends on the concrete capabilities and legal position of the processing party. While this approach increases contextual precision, it has also attracted academic criticism for potentially fragmenting the concept of personal data across actors.

Appendix B

EU AI ACT and MDR: relevant guidelines and articles

1. **High-risk classification under the AI Act**
   - Legal basis: Annex I Section A No. 11 AIA.
   - AI systems that are safety components of products, or are themselves products, subject to third-party conformity assessment under sectoral EU legislation (including the MDR) are automatically classified as high-risk.
   - This includes medical device software falling within the scope of the MDR where a notified body is involved.
2. **Substantive obligations for high-risk AI systems (AI Act)**
   - Art. 9 – Risk management system: Continuous, documented risk identification, analysis, evaluation, and mitigation throughout the lifecycle.
   - Art. 10 – Data and data governance: Requirements on training, validation, and testing data quality, relevance, representativeness, and bias mitigation.
   - Art. 11 & Annex IV – Technical documentation: Comprehensive documentation enabling assessment of compliance, including system description, intended purpose, design specifications, and risk management measures.
   - Art. 14 – Human oversight: Measures ensuring effective human control and the ability to intervene.
   - Art. 15 – Accuracy, robustness, and cybersecurity: Performance requirements proportionate to the intended purpose and risk profile.
3. **Qualification as medical device software under the MDR**
   - Legal basis: Rule 11, Annex VIII MDR.
   - Software intended to provide information for diagnostic or therapeutic purposes qualifies as medical device software.

- Risk classification (Class I, IIa, IIb, III) depends on the potential impact of the software's output on patient management and health outcomes.
- Class IIa or higher generally requires third-party conformity assessment by a notified body.

4. **Interaction between MDR and AIA**
   - Where medical device software is subject to third-party conformity assessment under the MDR, it is automatically classified as high-risk under Annex I Section A AIA.
   - Conformity assessments may be aligned or integrated, but the substantive requirements of both regimes apply cumulatively.

Other elements of the EU regulatory ecosystem include the Data Act [European Parliament and Council of the European Union, 2023]37, the Data Governance Act [European Parliament and Council of the European Union, 2022], and the European Health Data Space (EHDS) Regulation [European Parliament and Council of the European Union, 2025] which primarily structure data access and reuse frameworks and indirectly influence patient privacy. As the EU framework for digital regulation is still emerging, the practical interpretation of many sources is driven by guidelines, codes of practice, and supporting documents produced by the European Commission and various stakeholder groups, such as the European Data Protection Board (EDPB) [Barberá, 2025], European Artificial Intelligence Board (AIB) [European Commission, 2026a], Medical Device Coordination Group (MDCG) [European Commission, 2026b], and the European Association of Data Protection Professionals (EADPP) [European Federation of Data Protection Officers (EFDPO), 2021].